Who can touch which data · runtime database roles

Each service uses its own database role and connection pool. Ownership is checked on every route and again inside the result functions. Source: SPEC.md §5, §12, §15.

Portal API
organiser routes and sign-in

Can
- verified users and sessions
- its owner's poll configuration
- the eligibility list the owner supplied

Cannot
- read claim rows or raw responses
- reach another organiser's polls
- see live counts or claim status

Issuer
separate role and pool in the portal deployment

Can
- read verified identities and eligibility
- run the atomic claim insert
- load this poll's private key for the signer

Cannot
- read response rows or result snapshots
- expose per-account claim status to organisers

Public submission
response API, no sign-in

Can
- read the public poll, key and question view
- call the narrow redemption function, which compares answers inside the database and returns only the outcome

Cannot
- read identity tables
- read private-key references
- read arbitrary responses or snapshots

Results function
reviewed, owner-gated database function or job

Can
- finalize closure under the closure lock
- build or read the result snapshot
- read answer values, only while building it

Cannot
- give the portal SELECT on responses
- skip the ownership or threshold checks

Background and deployment
closure job, hourly purge, migrations

Can
- mark expired polls closed
- delete data at each retention boundary
- run migrations (deployment-only owner)

Cannot
- serve public requests
- delete single live claims or nullifiers
- run as superuser inside an API

identity.*
users (issuer, subject) · sessions
oauth_transactions · eligibility
claims (poll, user, entry)

polls · signing_keys
configuration, state, frozen schema
public keys; public views omit
private-key references

anonymous.*
responses (poll, nullifier, answers)
result_snapshots (ready results only)

operations.purge_tombstones
poll ID and purge date only,
kept one year

Database rules
- Public and default table grants revoked. Every runtime role gets only what is listed above.
- SECURITY DEFINER functions (if used): fixed safe search_path, explicit EXECUTE grants, no untrusted dynamic SQL, and every ownership and state check inside the function.
- No response timestamps, request IDs or IP columns. Claims and nullifiers are never truncated or reset for a live poll; accounts are never deleted to reset an entitlement.